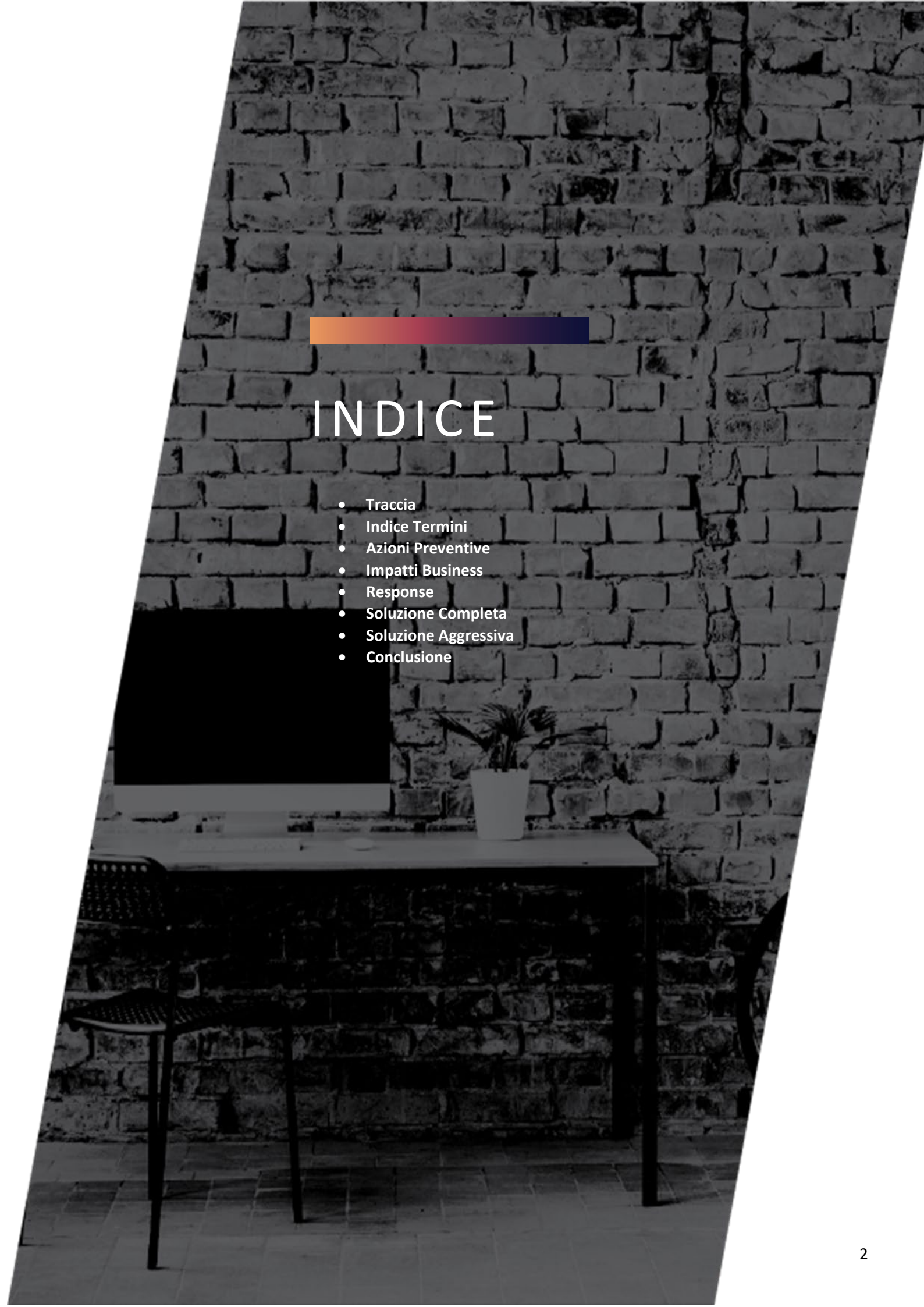


ESERCIZIO BENCHMARK M5

Giuseppe Federico



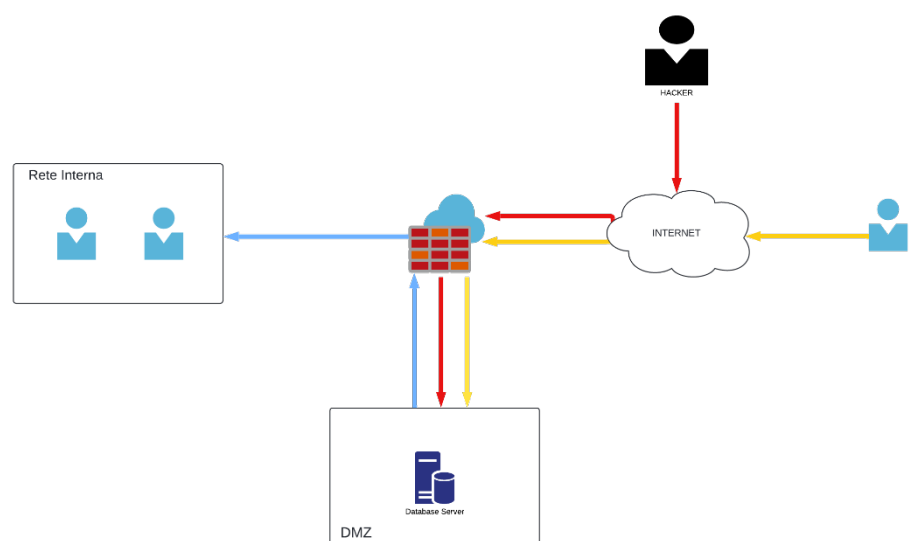
INDICE

- Traccia
- Indice Termini
- Azioni Preventive
- Impatti Business
- Response
- Soluzione Completa
- Soluzione Aggressiva
- Conclusione

TRACCIA

Con riferimento alla figura nella slide successiva, rispondere ai seguenti quesiti.

1. Azioni preventive: quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da attacchi di tipo SQLi oppure XSS da parte di un utente malintenzionato? Modificate la figura in modo da evidenziare le implementazioni
2. Impatti sul business: l'applicazione Web subisce un attacco di tipo Ddos dall'esterno che rende l'applicazione non raggiungibile per 10 minuti. Calcolare l'impatto sul business dovuto alla non raggiungibilità del servizio, considerando che in media ogni minuto gli utenti spendono 1.500 € sulla piattaforma di e-commerce.
3. Response: l'applicazione Web viene infettata da un malware. La vostra priorità è che il malware non si propaghi sulla vostra rete, mentre non siete interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infettata. Modificate la figura in slide 2 con la soluzione proposta.
4. Soluzione completa: unire i disegni dell'azione preventiva e della response (unire soluzione 1 e 3)
5. Modifica <<più aggressiva>> dell'infrastruttura (se necessario/facoltativo magari integrando la soluzione al punto 2)





INDICE TERMINI

DMZ

La DMZ, acronimo di “Demilitarized Zone”, (Zona Demilitarizzata) è una rete perimetrale che protegge la rete locale (LAN) interna di un’organizzazione dal traffico non attendibile. Essa indica comunemente una sottorete che si trova tra la rete Internet pubblica e le reti Private.

Le organizzazioni in genere archiviano nella DMZ servizi e risorse rivolti all’esterno, nonché server DNS, FTP, posta, proxy, VoIP e server Web..

In pratica, un approccio con la DMZ rende più difficile per un hacker ottenere l’accesso diretto ai dati e ai server interni di un’organizzazione tramite internet.

Rete Interna

Una rete interna aziendale, nota anche come Intranet, è una rete aziendale che è completamente isolata dalla rete esterna (Internet) a livello di servizi offerti.

Questa rete rimane solo a uso interno, comunicando eventualmente con la rete esterna e altre reti attraverso opportuni sistemi di sicurezza, come firewall o proxy server. In sintesi, una rete interna è un sistema di comunicazione sicuro e isolato utilizzato per lo scambio di informazioni all’interno di un’organizzazione.

Firewall

All’interno della rete è presente un Firewall, un sistema di sicurezza della rete informatica che limita il traffico Internet in entrata, in uscita o all’interno di una rete privata. Questo software o unità hardware-software dedicata, funziona bloccando o consentendo in maniera selettiva i pacchetti di dati. Un Firewall decide quale traffico di rete può passare e quale è pericoloso, separando l’attendibile dal non attendibile. I Firewall sono pensati per garantire la sicurezza delle reti private e dei dispositivi endpoint al loro interno, detti host di rete.

WAF

Nel contesto di una rete aziendale, il WAF agisce come un baluardo tra l’applicazione web e il traffico Internet in entrata, che può includere sia utenti legittimi che potenziali aggressori. Questo significa che tutte le richieste web dirette all’applicazione passano prima attraverso il WAF, che esamina ogni richiesta alla ricerca di possibili segnali di attività sospetta o malevola. Operando quindi al settimo livello della pila ISO/OSI (Application Server).

DDoS

Un attacco DDoS, o Distributed Denial of Service, è una forma di attacco informatico che ha l’obiettivo di rendere un servizio online, come un sito web, inutilizzabile inondandolo con un volume di traffico di rete eccessivo. Durante un attacco DDoS, l’attaccante sfrutta una rete di computer, spesso denominata “botnet”, per inviare un gran numero di richieste al sistema bersaglio. Queste richieste possono superare la capacità del sistema di gestirle, provocando rallentamenti o addirittura un’interruzione totale del servizio.

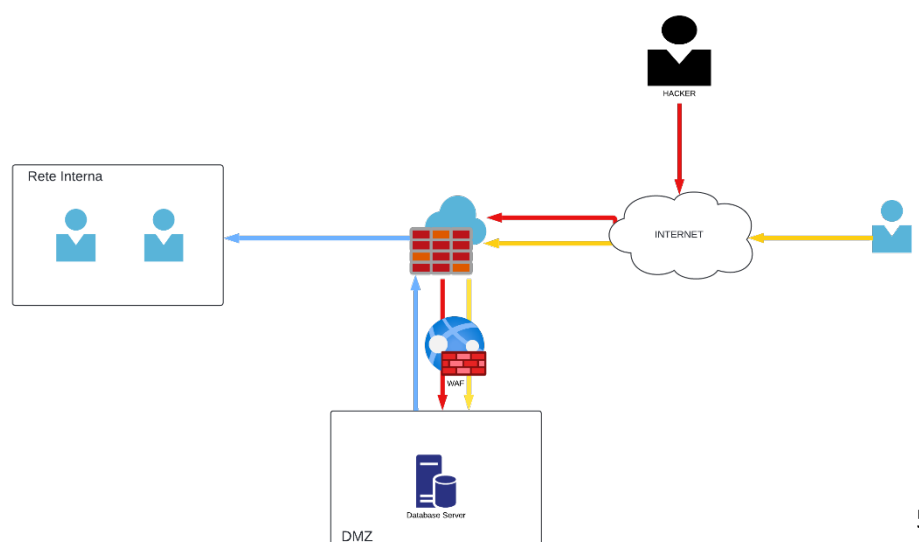
AZIONI PREVENTIVE

Attacchi SQLi (SQL Injection):

- **Input Validation:** Implementare la validazione degli input per garantire che i dati immessi dagli utenti siano conformi alle aspettative del sistema.
- **Parameterized Queries:** Utilizzare Parameterized query o prepared statements per evitare l'iniezione di codice SQL.
- **WAF (Web Application Firewall):** Configurare un WAF per rilevare e bloccare tentativi di SQLi.
- **Escaping Data:** Escape corretto dei dati immessi dagli utenti prima di includerli nelle query SQL.

Attacchi XSS (Cross-Site Scripting):

- **Sanitization and Encoding:** Sanitizzare e codificare tutti i dati immessi dagli utenti prima di renderizzarli nelle pagine web.
- **Content Security Policy (CSP):** Implementare una CSP per limitare le fonti di contenuti scriptabili che il browser può eseguire.
- **Input Validation:** Validare e limitare i tipi di dati che possono essere immessi dagli utenti.





IMPATTI SUL BUSINESS

Descrizione dell'Attacco:

- Tipo di Attacco: DDoS (Distributed Denial of Service)
- Durata dell'Impatto: 10 minuti di inattività

Calcolo dell'Impatto Economico:

- Perdita per Minuto: €1,500
- Totale Perdita: $1,500\text{€} \times 10\text{minuti} = 15,000\text{€}$

Azioni Preventive:

- CDN (Content Delivery Network): Utilizzare una CDN per distribuire il traffico e ridurre il carico sul server.
- DDoS Protection Services: Abbonarsi a servizi di protezione DDoS per mitigare gli attacchi in tempo reale.
- Rate Limiting: Implementare politiche di rate limiting per limitare il numero di richieste per utente.
- Scalabilità Automatica: Configurare sistemi di scalabilità automatica per gestire picchi di traffico improvvisi.

RESPONSE

Isolamento della Macchina Infetta:

- Disconnettere immediatamente la macchina infetta dalla rete per prevenire la propagazione del malware.

Incident Response Team:

- Attivare il team di risposta agli incidenti per analizzare e contenere la minaccia.

Logging and Monitoring:

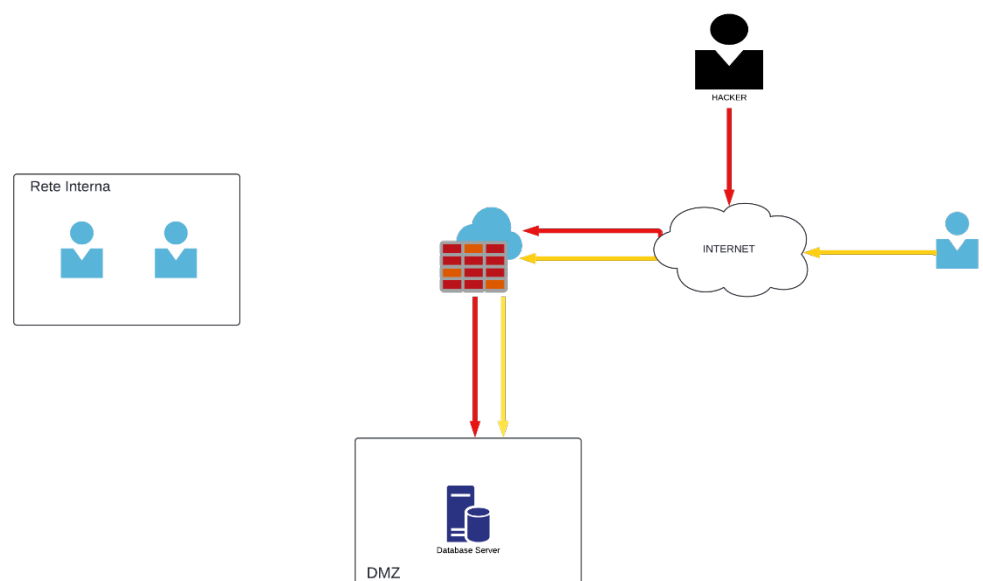
- Abilitare logging dettagliato per monitorare le attività sospette e identificare il punto di ingresso del malware.

Tenendo conto dell'urgenza, è possibile implementare un approccio che prevede l'isolamento del computer infetto.

In questa situazione, la DMZ sarà connessa direttamente a internet, accessibile all'aggressore, ma non sarà più collegato alla rete interna. L'immagine successiva illustra la soluzione che impiega la tattica dell'isolamento del server infetto.

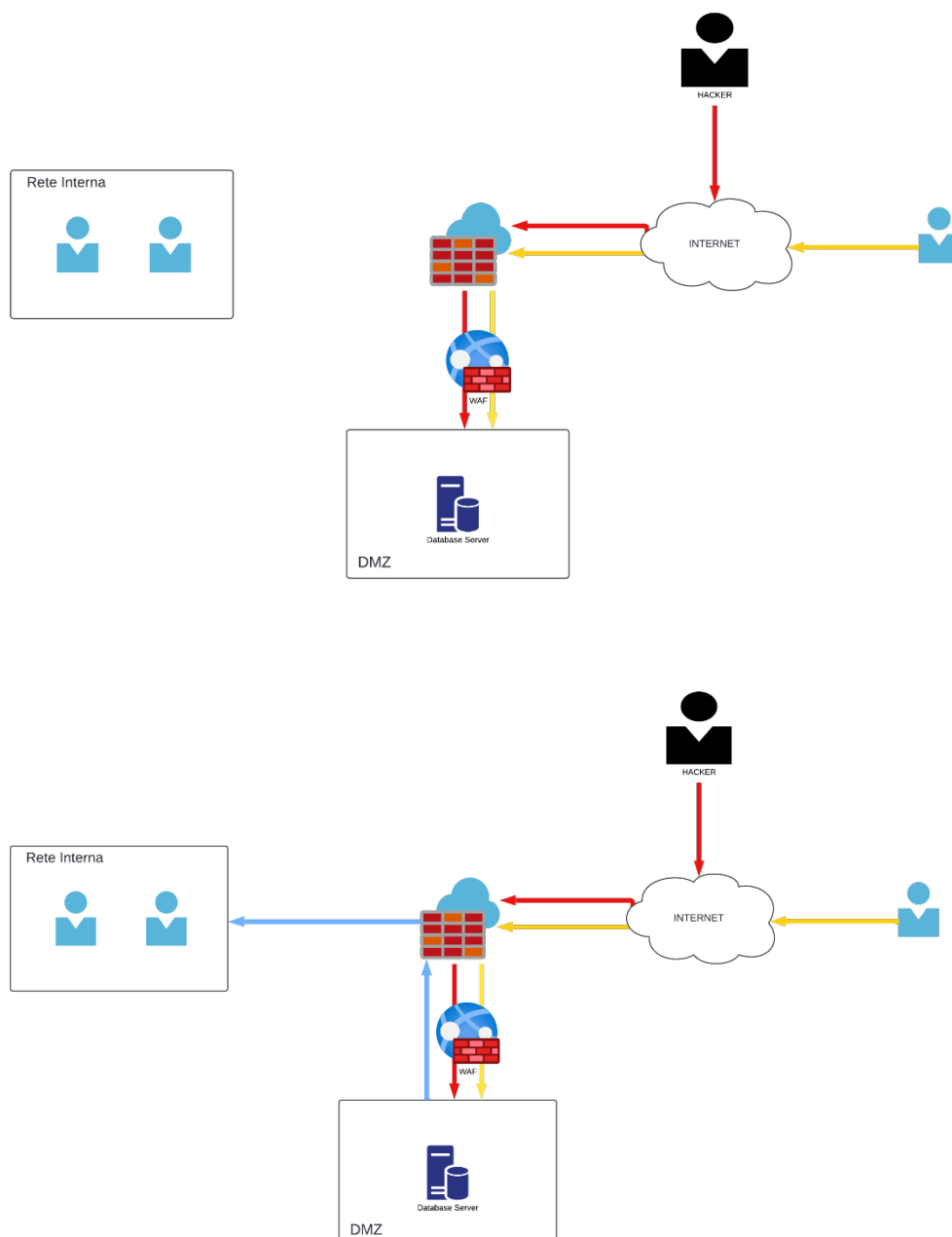
Si può notare che non c'è più alcuna comunicazione tra l'applicazione web e la rete interna.

Successivamente attiviamo il Team di Incident Response per analizzare e contenere la minaccia prima di ricollegare la rete interna, una volta che il team di IR applica le soluzioni si ricollega la rete interna utilizzando procedure costanti di logging e monitoring per identificare qualsiasi procedura non conforme con le attività aziendali.



SOLUZIONE COMPLETA

Unendo le soluzioni preventive e di response, possiamo ottenere un'ottima difesa contro gli attacchi informatici. La combinazione delle misure descritte sopra garantirà un'adeguata protezione e risposta agli incidenti, mantenendo la sicurezza e l'integrità dell'applicazione di e-commerce. Tenendo conto che in caso di attacchi come mostrato in figura basta temporaneamente la rete interna non connessa alla rete





SOLUZIONE AGGRESSIVA

Implementazione di Zero Trust Architecture:

- Microsegmentation: Dividere la rete in segmenti più piccoli e applicare politiche di sicurezza specifiche a ciascun segmento.
- Least Privilege Access: Implementare il principio del minimo privilegio, garantendo accesso solo alle risorse necessarie per il compito specifico.
- Multi-Factor Authentication (MFA): Richiedere l'autenticazione a più fattori per accedere a tutte le risorse critiche.

Enhanced Monitoring and Response:

- SIEM (Security Information and Event Management): Utilizzare un sistema SIEM per raccogliere, analizzare e rispondere agli eventi di sicurezza in tempo reale.
- Automated Incident Response: Implementare soluzioni di risposta agli incidenti automatizzate per rispondere rapidamente e efficacemente alle minacce.



CONCLUSIONE

Tramite l'utilizzo di questo report possiamo trovare delle soluzioni adatte alle problematiche che vengono riscontrate nell'esercitazione presa in considerazione. Implementando le soluzioni descritte, è possibile rafforzare la struttura di rete e mitigare significativamente i rischi possibili in caso di attacchi alla rete.